

Matriz de Riesgos — Actividad A03

Administración de Riesgos · Seguridad Aplicada a Sistemas de Información

1. Datos Generales

Nombre de la empresa / organización	Centro Médico del Valle (clínica privada, nombre ficticio)
Rubro / Industria	Salud — atención médica privada
Tamaño (empleados / facturación)	120 empleados · ~800 pacientes/día
Alumno(s) / Grupo	Juan Narváez (Juanchi) — Comisión 4°G
Legajo(s)	31631196
Fecha de elaboración	Septiembre 2026
Responsable del análisis	Juan Narváez

2. Objetivo y Alcance del Análisis

Objetivo: identificar, valorar y tratar los riesgos de seguridad de la información más relevantes para la operación de la clínica, a raíz de una auditoría externa que detectó debilidades en su gestión de riesgos, con el fin de priorizar inversiones de seguridad y reducir la exposición sobre los datos de pacientes y la continuidad de la atención.

Alcance: sistemas de historias clínicas digitales, base de datos de pacientes, módulo de facturación e interfaz con obras sociales, correo corporativo y estaciones de trabajo administrativas, infraestructura de servidores y dispositivos móviles del personal. No incluye equipamiento médico biomédico ni sistemas de terceros fuera del control directo de la clínica.

3. Inventario y Clasificación de Activos

ID	Descripción del Activo	Tipo	Responsable	Clasif.	Criticidad
A01	Servidor de historias clínicas (HCE)	Información	Gerencia de TI	Restringida	Alta
A02	Base de datos de pacientes (MySQL)	Información	Gerencia de TI	Restringida	Alta
A03	Almacenamiento de estudios por imágenes	Información	Gerencia de TI	Restringida	Alta
A04	Credenciales de usuarios y accesos	Información	Adm. de Sistemas	Confidencial	Alta
A05	Estaciones de trabajo administrativas	Hardware	Adm. de Sistemas	Interna	Media
A06	Correo corporativo	Software	Adm. de Sistemas	Interna	Media
A07	Módulo de facturación / interfaz obras sociales	Software	Jefe de Facturación	Confidencial	Alta
A08	Dispositivos móviles del personal (notebooks/tablets)	Hardware	Adm. de Sistemas	Confidencial	Media
A09	Infraestructura de servidores (sala, energía)	Hardware/Red	Gerencia de TI	Interna	Alta
A10	Personal médico y administrativo	Humano	Dirección Médica	Interna	Media

4. Identificación de Amenazas y Vulnerabilidades

ID	Activo	Descripción de la Amenaza	Tipo	Vulnerabilidad Asociada
T01	A01,A03	Ataque de ransomware que cifra los servidores de HCE	Intencional	Falta de EDR y segmentación de red
T02	A02,A04	Exfiltración de datos de pacientes por acceso no autorizado	Intencional	Sin cifrado en reposo ni DLP
T03	A05,A06	Phishing dirigido al personal administrativo	Intencional	Falta de capacitación formal y de MFA
T04	A01,A02	Pérdida irreversible de datos ante incidente mayor	Accidental	Backups sin prueba de restauración
T05	A04	Uso indebido de privilegios excesivos / cuentas compartidas	Intencional	Falta de RBAC y revisión de accesos
T06	A07	Exposición de datos en la interfaz con obras sociales	Accidental	Falta de cifrado TLS extremo a extremo
T07	A02,A10	Incumplimiento de la Ley 25.326 de Datos Personales	Accidental	Sin política formal de datos ni DPO
T08	A08	Robo o pérdida de dispositivos móviles sin cifrado	Intencional	Sin cifrado de disco ni MDM
T09	A09	Falla de infraestructura por falta de redundancia	Natural/Accidental	UPS insuficiente, sin generador

5. Escalas de Valoración

5.1. Escala de Probabilidad

Valor	Nivel	Descripción
1	Raro	El evento solo ocurriría en circunstancias excepcionales.
2	Improbable	Podría ocurrir, pero no se espera que suceda.
3	Posible	Existe una posibilidad real de que ocurra.
4	Probable	Es muy probable que ocurra en algún momento.
5	Casi seguro	Se espera que ocurra frecuentemente / ha ocurrido recientemente.

5.2. Escala de Impacto

Valor	Nivel	Descripción
1	Insignificante	Impacto mínimo, sin consecuencias operativas ni económicas relevantes.
2	Menor	Alteración leve de la operación, costo bajo.
3	Moderado	Impacto operativo y económico apreciable, recuperable.
4	Mayor	Impacto significativo, pérdida de operación o datos, costo alto.
5	Catastrófico	Paralización total, pérdida crítica de datos, daño reputacional o legal severo.

6. Matriz de Calor (Probabilidad x Impacto)

Se ubican los 9 riesgos identificados (R01–R09) según su probabilidad (eje vertical) e impacto (eje horizontal). El color de cada celda indica el nivel de riesgo resultante.

P \ I	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12 R05	16 R03	20 R01
3	3	6	9 R08,R09	12 R06,R07	15 R02,R04
2	2	4	6	8	10
1	1	2	3	4	5

6.1. Niveles de Riesgo

Nivel	Rango (P×I)	Color	Acción requerida
Bajo	1 – 4	Verde	Monitorear. Puede aceptarse.
Medio	5 – 9	Amarillo	Plan de acción a mediano plazo.
Alto	10 – 15	Naranja	Tratamiento prioritario a corto plazo.
Crítico	16 – 25	Rojo	Acción inmediata. Escalar a dirección.

7. Evaluación de Riesgos

ID	Activo	Amenaza	Prob.	Imp.	Valor	Nivel	Justificación breve
R01	A01	T01	4	5	20	Crítico	Sector salud muy golpeado por ransomware (DBIR); paraliza la atención.
R02	A02	T02	3	5	15	Alto	Datos de salud son sensibles (Ley 25.326); fuga con sanciones severas.
R03	A05	T03	4	4	16	Crítico	Elemento humano en la mayoría de brechas; 120 empleados sin MFA.
R04	A01	T04	3	5	15	Alto	Debilidad ya detectada por auditoría; agrava cualquier incidente.
R05	A04	T05	4	3	12	Alto	Práctica habitual sin gestión de identidades; facilita fraude interno.
R06	A07	T06	3	4	12	Alto	Integraciones externas con configuraciones heredadas sin cifrado.
R07	A02	T07	3	4	12	Alto	Brechas de cumplimiento frecuentes; auditoría señaló debilidades.
R08	A08	T08	3	3	9	Medio	Movilidad del personal aumenta exposición de dispositivos.
R09	A09	T09	3	3	9	Medio	Cortes de energía habituales sin redundancia adecuada.

8. Tratamiento de Riesgos y Riesgo Residual

Riesgo	Estrategia	Salvaguardas propuestas	Tipo	Prob. resid.	Imp. resid.	Val. resid.	Nivel resid.
R01	Mitigar	EDR en endpoints/servidores, segmentación de red, parcheo mensual (PA-01)	Técnica	2	4	8	Medio
R02	Mitigar	Cifrado en reposo, mínimo privilegio, logging y DLP (PA-02)	Técnica	2	4	8	Medio
R03	Mitigar	Capacitación trimestral y MFA en correo/sistema clínico (PA-03)	Admin.	2	3	6	Medio
R04	Mitigar	Backups 3-2-1 con pruebas periódicas de restauración	Técnica	2	3	6	Medio
R05	Mitigar	RBAC con mínimo privilegio, baja de cuentas compartidas	Admin.	2	3	6	Medio
R06	Mitigar	Cifrado TLS extremo a extremo, validación y monitoreo	Técnica	2	3	6	Medio
R07	Mitigar	Programa de cumplimiento y designación de responsable de datos	Admin.	2	3	6	Medio
R08	Mitigar	Cifrado de disco (BitLocker/LUKS) y MDM básico	Técnica	2	2	4	Bajo
R09	Mitigar/Aceptar	UPS dimensionada, generador, alta disponibilidad	Física	2	2	4	Bajo

Tipo de salvaguarda: Técnica / Física / Administrativa. Con el tratamiento propuesto, ningún riesgo permanece en nivel Alto o Crítico: los dos riesgos originalmente críticos (R01, R03) bajan a Medio, y los cinco riesgos Altos también bajan a Medio, mientras que R08 y R09 bajan de Medio a Bajo.

9. Resumen de Resultados

Nivel	Cantidad de riesgos	% del total
Crítico	2	22,2 %
Alto	5	55,6 %
Medio	2	22,2 %
Bajo	0	0 %
Total	9	100 %

10. Conclusiones y Recomendaciones

El análisis muestra que más del 77% de los riesgos identificados se ubican en niveles Alto o Crítico, lo que confirma las debilidades detectadas por la auditoría externa y justifica una intervención prioritaria. Los dos riesgos críticos (ransomware y phishing) comparten una causa raíz común: la ausencia de controles técnicos básicos (EDR, MFA) y de concientización del personal, por lo que atacarlos en conjunto (planes PA-01 y PA-03) genera el mayor retorno en reducción de riesgo. Se recomienda a la Dirección aprobar el presupuesto conjunto de los tres planes de acción (aproximadamente USD 24.000), designar formalmente a los responsables de cada plan y establecer una revisión trimestral del registro de riesgos en SimpleRisk para verificar que el riesgo residual se mantenga dentro de los niveles Bajo/Medio proyectados.

11. Declaración de Buenas Prácticas

Compromiso profesional: Como estudiante de Seguridad Aplicada a Sistemas de Información, declaro que el presente análisis de riesgos fue elaborado aplicando las buenas prácticas de la disciplina, con criterio ético, fundamentos técnicos y respetando el marco normativo vigente.

Juan Narvaez

Firma del alumno/a

06/09/2026

Fecha

12. Referencias Bibliográficas

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática*. IFCT0109 (2.^a ed.). IC Editorial — eLibro.
- ISO/IEC (2005). *Information security management 27001*.
- ISO/IEC (2018). *ISO/IEC 27005: Information security risk management*.
- NIST (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*.
- OWASP Risk Rating Methodology: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology
- Verizon (2025/2026). *Data Breach Investigations Report (DBIR)*.